

Informe de auditoria — Total Secure App (DT360 Core)

Fecha: 2026-09-15 · **Version:** 2.0 (con las correcciones aplicadas) **Ruta:** /home/server-dt/Documentos/totalsecureapp

Resumen ejecutivo

Sistema de gestion operativa de guardias de seguridad: accesos, rondas, biometria, inventario y alertas, con aplicacion movil Android. **Es el sistema mas grande del servidor** (57 tablas, 880 usuarios, 4,5 GB en disco) y el **unico alcanzable desde internet**.

Esta bien construido: Laravel modular, Sanctum y spatie/permission (las librerias correctas, no invenciones), PostgreSQL limitado a 127.0.0.1, secretos con fail-fast, y la **mejor documentacion del servidor** — incluido un LEEME-apk.txt que publica la huella del certificado y explica por que una version del APK no debe repartirse.

⚠ Correccion de la version 1.0 (el hallazgo, ya corregido)

La documentacion de la API ruta por ruta destapo **una toma de cuentas** que la primera pasada no vio: POST /api/procesar_paswchg es publico y **cambia la contraseña de cualquier usuario sin validar ningun token**. Basta el user_id, que es un entero secuencial.

Eso desplaza la prioridad: **por delante incluso de activar HTTPS**.

La primera pasada reviso configuracion, exposicion, Docker y secretos. Lo que no reviso fue el codigo de cada controlador.

El problema, ahora en dos frentes

Primero: cualquiera puede tomar cualquier cuenta. POST /api/procesar_paswchg no exige autenticacion y no comprueba el token de recuperacion que el propio sistema emite. Una peticion con {"user_id":1,"password":"...","password2":"..."} cambia la contraseña de ese usuario. Y POST /api/solicitud_paswchg, tambien publico, **devuelve el token y el user_id en la respuesta**.

Segundo: datos biometricos de 880 personas viajan por internet sin cifrar. Tres hechos verificados que se refuerzan: el sistema responde en http://181.198.245.50:3031 (302), el backend se configura con esa URL sin TLS, y la app movil **desactiva explicitamente** la proteccion de Android contra trafico en claro (usesCleartextTraffic: true).

Una contraseña filtrada se cambia. Una huella o un rostro, no.

Y no hay ningun respaldo. Ni de la base, ni de los secretos, ni del keystore que firma la aplicacion — sin el cual no se pueden publicar actualizaciones nunca mas.

Lo notable: la solucion al hallazgo critico **ya esta escrita en el proyecto.** `docker-compose.prod.yml` define nginx 1.27 con certbot y puertos 80/443, y `DESPLIEGUE-DOMINIO.md` documenta el procedimiento. Solo falta activarlo.

Estado general

EN CORRECCION — actualizado el 2026-09-15, al cierre de la jornada.

De los cuatro hallazgos criticos, **tres estan resueltos y verificados:**

	Hallazgo	Estado
SEC-00	Toma de cuentas por <code>procesar_paswchg</code>	☒ CERRADO — y tambien la misma via en el portal web
CONT-01	Sin respaldo	☒ HECHO — diario a las 03:00, probado restaurando
SEC-05	Fuga entre instituciones (T-30)	☒ CERRADO — era real: detalle de rondas y marcadores
SEC-01	Biometria sin cifrar por internet	☐ ABIERTO — a la espera de liberar el dominio
CONT-02	Keystore sin copia fuera del servidor	☐ PARCIAL — respaldado, pero en el mismo servidor

Lo que queda como critico es **la falta de HTTPS**, y esta detenido por una dependencia externa al equipo tecnico: no hay dominio asignado todavia. El `docker-compose.prod.yml` con certbot sigue listo para el dia que se libere.

CONT-02 esta a medias por la misma clase de motivo: el respaldo existe y se verifico, pero **no hay todavia un destino fuera de este servidor** donde copiarlo. El script ya tiene el paso preparado (`DESTINO_EXTERNO`) y avisa en cada corrida mientras siga vacio.

Arquitectura

Laravel 13 modular (Acceso, Administracion, MobileApp, PortalApi) + PHP 8.3 + PostgreSQL 16 + nginx, mas app React Native/Expo. Contenedor MariaDB suelto con la base heredada V1.

Codigo

No se evaluo linea por linea. Las decisiones de dependencias son correctas: Sanctum para tokens, spatie/laravel-permission para roles, dompdf para PDF. La modularizacion permite que la API movil evolucione sin arrastrar al portal.

Docker

Correcto en lo esencial: base solo local, fail-fast en `DB_PASSWORD`, healthcheck con `service_healthy`.
Debilidad: bind mounts del código fuente en producción.

Hallazgo positivo verificado: el comentario del compose documenta un incidente previo — `APP_DEBUG=true` en producción filtrando la contraseña de la base por las trazas de Ignition— y **hoy esta corregido:** `APP_ENV=production`, `APP_DEBUG=false`.

Base de datos

PostgreSQL 16, 57 tablas, correctamente limitada a `127.0.0.1`. 880 usuarios, 12.664 biometrias, 9.769 accesos, 8.667 rondas. **Las 57 tablas no estan documentadas una por una:** es el trabajo pendiente mas grande.

Seguridad

2 criticos, 2 altos, 4 medios. El primero es la toma de cuentas; el segundo, la exposicion sin cifrar.

Lo que **si** esta bien resuelto: el login (Hash::check, estado, gestion y rol antes de emitir el token), el webhook de WhatsApp (`hash_equals` y 404 sin token configurado — la mejor implementacion del servidor), y que solo 4 de 55 rutas sean publicas.

Documentacion

La mas completa del servidor. Trece documentos previos, seis fases de historia de construccion, especificacion OpenAPI, guias de despliegue y migracion. `LEEME-apk.txt` es un ejemplo de documentacion operativa util: explica no solo que instalar sino **que NO instalar y por que**.

Backup

☐ **Inexistente**, con cuatro elementos irrecuperables: base principal, base V1, secretos y **keystore de firma**.

Operacion

Unico sistema expuesto a internet. Sin monitoreo. Healthcheck solo en la base.

Mobile

☐ **Documentado completo.** App `com.dt360.coreapp` 1.0.2 (versionCode 3), React Native/Expo, cinco permisos sensibles, firmada con certificado propio de huella publicada.

Dato operativo relevante: hasta la version 1.0.2 **el boton de EMERGENCIA no existia** en la aplicacion de los guardias. Conviene confirmar que todas las tablets fueron actualizadas.

Riesgos

Riesgo	Probabilidad	Impacto	Exposicion
~~Toma de cualquier cuenta~~	—	—	☐ cerrada el 2026-09-15, por las dos vias
Interceptacion de biometria y credenciales	media-alta	muy alto	muy alta — internet, sin TLS
Perdida total de datos	baja	muy alto	media — hay respaldo diario, pero en el mismo servidor
Perdida del keystore	media	muy alto	alta — sin copia; imposibilita actualizar la app
Tablets sin boton de panico	media	alto	media — si alguna sigue por debajo de 1.0.2
~~Fuga entre instituciones~~	—	—	☐ verificada y cerrada el 2026-09-15
<code>v1_analisis</code> fuera de control	media	medio	media

Inconsistencias

INC-01 — Despliegue con HTTPS preparado y sin activar ☐

Configuracion prevista: `docker-compose.prod.yml` con nginx 1.27, certbot y puertos 80/443; `DESPLIEGUE-DOMINIO.md` documenta el procedimiento. **Realidad:** corre `docker-compose.yml` con nginx:alpine en el 3031, sin TLS. **Impacto: critico.** La solucion al mayor riesgo del sistema existe y no se uso.

INC-02 — Contenedor `v1_analisis` fuera de todo compose

MariaDB 10.4 creado el 2026-09-07, sin proyecto compose. No se recrea, **no entra en ningun respaldo**, y no aparece en los archivos del proyecto. **Impacto:** medio.

INC-03 — `openapi.yaml` posiblemente desactualizado

Del 2026-09-07; los APK son del 08 y 09. No se contrasto contra las rutas reales. **Recomendacion:** usar `php artisan route:list` como referencia.

INC-04 — Las variables del compose pisan al `.env`

Documentado por el propio proyecto. Se registra porque **es una trampa que cuesta horas**: cambiar el `.env` no surte efecto.

INC-05 — `repomix-output.xml` en el proyecto

1,2 MB de volcado de codigo. No es documentacion y se desactualiza solo.

Documentacion faltante

- **Manual de usuario y manual de administrador**: requieren credenciales de prueba y una sesion dedicada. No se generaron para no inventar funcionalidades ni navegar produccion.
- **Las 57 tablas**, una por una.
- **Verificacion del aislamiento entre instituciones** (T-30).

Recomendaciones

ID	Hallazgo	Categoria	Severidad	Recomendacion
SEC-00	❑ RESUELTO — <code>procesar_paswchg</code> publico y sin validar token	Seguridad	❑ CRITICO	Hecho: codigo con <code>random_bytes</code> , guardado hasheado, con caducidad, de un solo uso y comparado con <code>hash_equals</code> ; ya no vuelve en la respuesta. El portal web tenia el mismo agujero y tambien se cerro
SEC-01	Biometria y credenciales por internet sin cifrar	Seguridad	❑ CRITICO	Activar HTTPS . Ya esta preparado en <code>docker-compose.prod.yml</code> . Luego quitar <code>usesCleartextTraffic</code> y recompilar el APK
CONT-01	❑ RESUELTO — Sin respaldo de base, secretos ni keystore	Continuidad	❑ CRITICO	Hecho: <code>scripts/respaldo.sh</code> diario a las 03:00, con los cuatro elementos. Verificado restaurando el indice del dump y comparando el SHA-256 del keystore
CONT-02	Keystore sin copia fuera del servidor	Continuidad	❑ CRITICO	Copia en almacen de secretos. Sin el, no hay mas actualizaciones de la app
SEC-02	Bind mounts de codigo en produccion	Seguridad	❑ ALTO	Imagen con <code>COPY</code> para produccion
SEC-05	❑ RESUELTO — Aislamiento entre instituciones sin verificar	Seguridad	❑ MEDIO	Se verifico y habia fuga : el detalle de rondas y los marcadores de local filtraban solo por el parametro de la URL. Un Supervisor leia rondas de otro cliente y editaba las coordenadas de sus QR . Cerrado, con 12 tests
MOV-01	Tablets posiblemente sin boton de panico	Operacion	❑ MEDIO	Censar versiones; actualizar a 1.0.2

ID	Hallazgo	Categoria	Severidad	Recomendacion
INC-02	v1_analisis fuera de control	Operacion	☐☐ MEDIO	Definir si la migracion concluyo; respaldar y apagar
OPS-01	Backend y nginx sin healthcheck	Operacion	☐☐ MEDIO	Agregarlos
INC-03	openapi.yaml a verificar	Documentacion	☐☐ BAJO	Contrastar con route:list
GES-01	Repositorio sin remoto	Gestion	☐☐ MEDIO	Publicar; el keystore exige ademas custodia aparte
DOC-01	57 tablas sin documentar	Documentacion	☐☐ MEDIO	Sesion dedicada

Prioridad recomendada

1. **SEC-00 — cerrar la toma de cuentas.** Hoy cualquiera en internet puede hacerse con la cuenta administrativa de un sistema con 12.664 biometrias. Va por delante de todo lo demas, incluido HTTPS: de nada sirve cifrar el canal si la puerta esta abierta.
2. **CONT-02 — copiar el keystore fuera del servidor.** Toma minutos y su perdida es irreversible.
3. **SEC-01 — activar HTTPS.** Ya esta preparado en `docker-compose.prod.yml`.
4. **CONT-01 — respaldo.** El sistema con mas datos del servidor no tiene ninguno.
5. **MOV-01 — censo de tablets.** Una app de guardias sin boton de panico es un riesgo operativo directo.
6. **SEC-05 / T-30 — aislamiento entre instituciones.**
7. SEC-02, INC-02, OPS-01 y el resto.

Ningun cambio fue aplicado durante esta auditoria.